

Cybersecurity Risk Assessment (Real Case Study)

Introduction

BioTerra is a biofuel production industry, primarily focused on ethanol, from which sub-products like dried distillers grains with solubles (DDGS) and oil are derived. Additionally, it operates two biogas plants fueled by production waste. The entire operation exists in a **100% On-Premise** environment where **IT/OT convergence** is the core of the business, and where ensuring operational continuity and data integrity is the central objective of the cybersecurity strategy.

Note on Confidentiality: The organization's name has been modified for privacy. This document represents a real-world case study; all analyses, findings, and strategic recommendations are based on authentic data from a live corporate environment.

This risk assessment was developed as a final capstone project for the Cybersecurity Diploma at UBP University.

Collaboration: The project was a collaborative effort with a cybersecurity colleague currently employed at the analyzed organization.

Organizational Profile — Critical Assets

Human Capital and Endpoints

- **Total Employees:** 300
- **Computing Devices:** 280
- **Mobile Density:** High density of mobile devices (personal and corporate smartphones, ratio exceeding 1:1).

Network Infrastructure

- **Physical Segmentation:** Double fiber optic ring for physical traffic segmentation.
- **IT Network (Corporate):** Active Directory + Fortinet. Includes guest and corporate wireless networks, and wired guest access with RADIUS authentication (802.1X).
- **OT Network (Automation):** HP switching, isolated from the internet except for three critical IT/OT convergence points.
- **Data Center:** 8 physical servers (4 IT / 4 OT). The infrastructure is 100% On-Premise, with one exception: daily backups are replicated to Microsoft Azure as an offsite copy within a 3-tier backup strategy.

IT Structure and Governance

- **Strategic Level:** Board of Directors (shareholders and partners) — defines investments and vision.
- **Executive Level:** CEO → Administrative Management.
- **Operational Level:**
 - 1 IT Leader (reporting to Administrative Management).
 - 3 Specialized Assistants: Application Development, Infrastructure, and Cybersecurity.

Maturity and Cybersecurity Strategy

Investment Context (2023–2026)

Following a wave of ransomware incidents in the Argentine regional agro-industrial sector, BioTerra initiated a sustained investment plan. The Board recognized that the **risk of plant shutdown (OT) far outweighs the cost of prevention.**

Co-management Model

BioTerra operates with an internal Cybersecurity assistant and a specialized third-party consultancy, providing:

- Strategic advisory aligned with **NIST**.
- EDR implementation and Fortinet firewall management.
- Continuous monitoring and advanced technical support for the 4 IT servers.
- **24/7 Monitored SOC.**

Evaluation Roadmap

- Maintain IT monitoring (85% integrated with Fortinet: 2 FortiGates in HA, EDR on servers/workstations, MFA, outsourced SOC).
- Extend visibility to the **OT network**, especially at the 3 critical IT/OT convergence nodes.
- Implement periodic vulnerability assessment tools, prioritized for OT.
- Monthly **phishing and ransomware exercises** segmented by profile; metrics on clicks and reporting. Red teaming with external consultants is planned within 2 years.
- **Pentesting** scheduled for 2027 (covering IT, OT, and convergence nodes).

Awareness Program

Current Status

At the end of 2025, BioTerra launched a Security Awareness program featuring phishing and ransomware simulation campaigns. The program continues through late 2026 via a partnership with Telecom, utilizing training tools fully subsidized under a current subscription. Initial results are favorable.

Objectives and Scope

To reduce human factor risk to protect operational continuity and data integrity. The plan covers all BioTerra personnel.

Content Proposals

- **Real Reference Cases:** Analyzing the ransomware case of the company “AGD,” drawing parallels with BioTerra.
- **Confidentiality:** Tools for protecting personal and corporate data.
- **Credential Management:** Complexity, uniqueness, rotation, MFA, and the use of password managers.
- **Profile-based Campaigns:** Board of Directors (whaling/spear phishing), Administrative staff (email and internal data), OT operators (external devices and unauthorized equipment).
- **Threat identification:** Ransomware and malware in general, transversal to all profiles.

Methodology

- **Annual Initial Training:** In-person class for all staff (including new hires).
- **Monthly “Pills”:** Content under 1 minute displayed on internal plant screens and banners.
- **Phishing Simulations:** Segmented by profile (Whaling for the Board, CEO fraud for Admin, technical alerts for IT/OT). Frequency: Quarterly.
- **Mobile Communications:** Alerts and updates regarding new attacks or ongoing campaigns via mobile messaging.

Ransomware

BioTerra's Current Status Against Ransomware

Protection with FortiEDR

FortiEDR acts as the last line of defense. Unlike traditional antivirus, it monitors the behavior of every process in real-time. If it detects suspicious activity (e.g., massive file encryption), it blocks the action automatically and immediately, even against zero-day attacks.

Network Segmentation

The IT network is fragmented into VLANs managed by Fortinet firewalls, eliminating unnecessary traffic between wireless, wired, guest, and IoT networks.

SOC — Security Operations Center

BioTerra operates with a SOC managed by an external firm under a co-management model:

Actor	Responsibility	Days	Hours
Specialized Firm (SOC)	Continuous alert monitoring and real-time analysis	7 days	24 hrs
Internal IT Team	Review of reports generated by the outsourced SOC	Mon–Fri	08:00–17:00

Preventive Measures and Assigned Resources

The following measures make up the defense-in-depth strategy. The responsible party, estimated dedication, and current status of each action are detailed:

Measure	Responsible	Frequency/Dedication	Status
Patch Management	Internal IT	Based on IT team availability	Active (continuous)
Digital Hygiene	Internal IT	To be planned in 2nd half of 2026	Pending
RDP / VPN Security + MFA	Internal IT	To be planned in 2nd half of 2026	Pending
Least Privilege	Internal IT	Based on IT team availability	Active (continuous)
SOC Monitoring	Specialized firm	24 hours / 7 days (continuous)	Active
SOC Report Review	Internal IT	Mon–Fri, 08:00–17:00	Active
Isolation and Containment	Internal IT	Immediate response to incidents	Defined protocol

Measure	Responsible	Frequency/Dedication	Status
Backup Restoration	Internal IT	Daily, weekly, and monthly	Defined protocol
Forensics and BCP	Internal IT	Post-incident	Pending
OT Network Segmentation	Internal IT	Based on OT team responsibility	Pending

Measure Details

- **Patch Management:** Updating of IT and OT servers according to the availability and criteria of the internal IT team. Principle: what cannot be seen cannot be protected.
- **Least Privilege:** No users (except IT) operate with administrator accounts for daily tasks.
- **Digital Hygiene (H2 2026):** Disabling macros and PowerShell where unnecessary, blocking TOR nodes in Fortinet, and showing file extensions.
- **RDP / Remote Access (2nd half 2026):** Remote desktop restricted behind VPN with mandatory MFA.
- **OT network segmentation:** implementation and strict rules on Fortinet firewalls, with least privilege access policies at the three critical IT/OT convergence nodes. As a next step, the incorporation of a dedicated SOC for OT is planned, replicating the model already implemented in the IT network. This implementation aims to be ready by the end of 2026.
- **Forensics and BCP:** The Forensic Analysis process and the Business Continuity Plan (BCP) are currently in the definition stage. Both documents are expected to be formalized before the close of the first half of 2026, with the participation of the internal IT team, the third-party cybersecurity firm, and department heads, under the validation of the CEO.

Impact Mitigation Proposal

Context BioTerra currently lacks a formalized **Business Continuity Plan (BCP)** and incident response procedure. This section establishes the baseline for acting against a confirmed ransomware attack, prioritizing plant operational continuity.

Recovery Time Objectives (RTO) Stored ethanol availability is the critical factor: exceeding 72 hours without production compromises delivery. **OT restoration is always the priority.**

Area	Max Tolerable Time	Desirable Time	Objective
Production (OT)	72 hrs	48 hrs	24 hrs
Administrative (IT)	120 hrs	72 hrs	48 hrs

Backup Strategy BioTerra implements a backup scheme on three media, complying with the 3-2-1 rule (3 copies, 2 different media, 1 offsite):

- **QNAP (Local Disk):** First line of restoration, fast recovery.
- **Cloud (Azure):** Offsite copy, beyond the reach of local encryption.
- **LTO Tape (Offline)** Disconnected from the network, making it immune to encryption. Final protection.

Frequencies:

- **Daily (Mon–Thu):** minimum operational data loss.
- **Weekly (Friday):** consolidation of the week.
- **Monthly (last Friday):** historical backup on LTO tape.

Implemented procedures

Detection and Contention

- FortiEDR automatically isolates compromised endpoints.
- IT blocks accounts and informs the SOC.
- The IT network has been segmented to protect the plant from the assets.

Response Procedure 1. Scope Assessment

- Determine which systems were encrypted and how far the intrusion reached.
- Identify the most recent clean backup available (QNAP → Azure → LTO).
- Estimate recovery time and compare it against target recovery objectives.

2. Restoration (OT Priority)

- Restore critical OT systems first to resume production within 24–72 hours.
- Validate backup integrity before restoration to avoid reinfection.
- Restore IT administrative systems in a second phase.

3. Ransom Decision

- Do not pay. There is no guarantee of key recovery or that the attacker will not re-encrypt the systems.
- The three-backup strategy makes payment unnecessary if procedures are correctly followed.

4. Exfiltration Management

Most modern ransomware uses double extortion. In this context:

- Assess whether sensitive information was stolen.
- Notify potentially affected clients, suppliers, and employees.
- Monitor leaks on ransomware.live and misp-project.org.

5. Forensic Analysis

- Identify the entry vector using Fortinet logs and endpoint data. Verified by the third-party cybersecurity firm advising BioTerra.
- Document the incident and adjust controls to prevent recurrence.
- Evaluate the company's legal responsibility regarding the data breach.

Suggestions for Strengthening Posture

- **Formalize the BCP:** Document the response procedure with defined roles, responsibilities, and system-specific time limits. This should be completed during the first half of the year, agreed upon by all department heads.
- **Periodic Restoration Tests:** Verify at least quarterly that backups are functional. A backup that hasn't been tested is not a reliable backup.
- **Protect the QNAP:** since it is connected to the network, it is the most vulnerable medium. It is recommended to configure immutable snapshots and restrict access only from the backup server.
- **Define a Playbook:** A step-by-step guide to ensure the team responds under pressure without improvising.

For its implementation, it is proposed to establish a Crisis Committee composed of the CEO, department heads, the IT lead, and the outsourced cybersecurity firm, with the objective of having it formed and operational before the end of 2026. This committee would have the following responsibilities:

- Make critical executive decisions during the incident (plant shutdown, communication to clients, legal intervention).
- Coordinate actions between internal IT, the outsourced cybersecurity provider, and department heads.

- Authorize prioritized system restoration based on operational impact.
- Manage external communication in the event of a potential data breach.
- Review and update the playbook periodically based on new incidents or infrastructure changes.